

# Sicurezza dell'Applicazione E-commerce

08/09/2026

*Obiettivo: analisi della sicurezza dell'architettura di rete a supporto di una piattaforma di e-commerce, con proposta di azioni preventive, valutazione degli impatti di business e definizione della risposta a incidenti (SQLi/XSS, DDoS, malware)*

## 1. Architettura di rete iniziale

L'applicazione di e-commerce deve essere disponibile agli utenti tramite Internet per effettuare acquisti sulla piattaforma, il server applicativo risiede in una zona demilitarizzata (DMZ), raggiungibile da Internet attraverso il firewall perimetrale. la rete interna è raggiungibile dalla DMZ per via delle policy configurate sul firewall: questo significa che, in caso di compromissione del server in DMZ, un attaccante potrebbe potenzialmente raggiungere anche la rete interna dell'azienda. Questa è l'architettura di partenza da cui muovono le analisi e le soluzioni proposte nei punti successivi

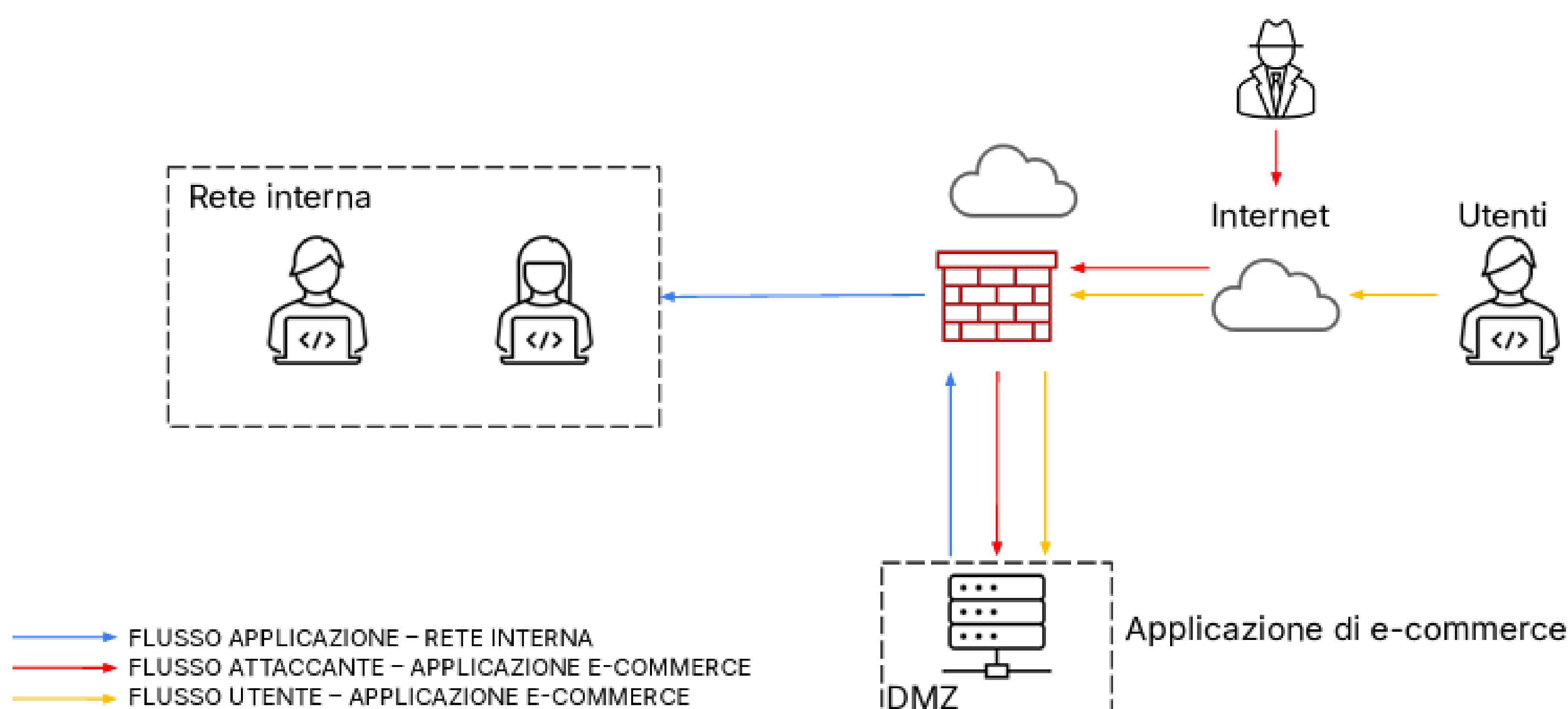


Fig. 1 — Architettura di rete di partenza: DMZ raggiungibile da Internet, rete interna raggiungibile dalla DMZ

## 2. Punto 1 — Azioni preventive contro SQL Injection e XSS

### Minacce considerate: SQL Injection (SQLi) e Cross-Site Scripting (XSS)

La SQL Injection sfrutta una validazione insufficiente dell'input per inserire codice SQL malevolo nei campi dell'applicazione, con l'obiettivo di leggere, modificare o cancellare dati nel database, oppure bypassare l'autenticazione. il Cross-Site Scripting inietta script eseguiti nel browser di altri utenti, con l'obiettivo di rubare sessioni/cookie o compiere azioni per conto della vittima, entrambi gli attacchi sfruttano una validazione insufficiente dell'input lato applicazione, per cui le contromisure architetturali e applicative si somigliano molto

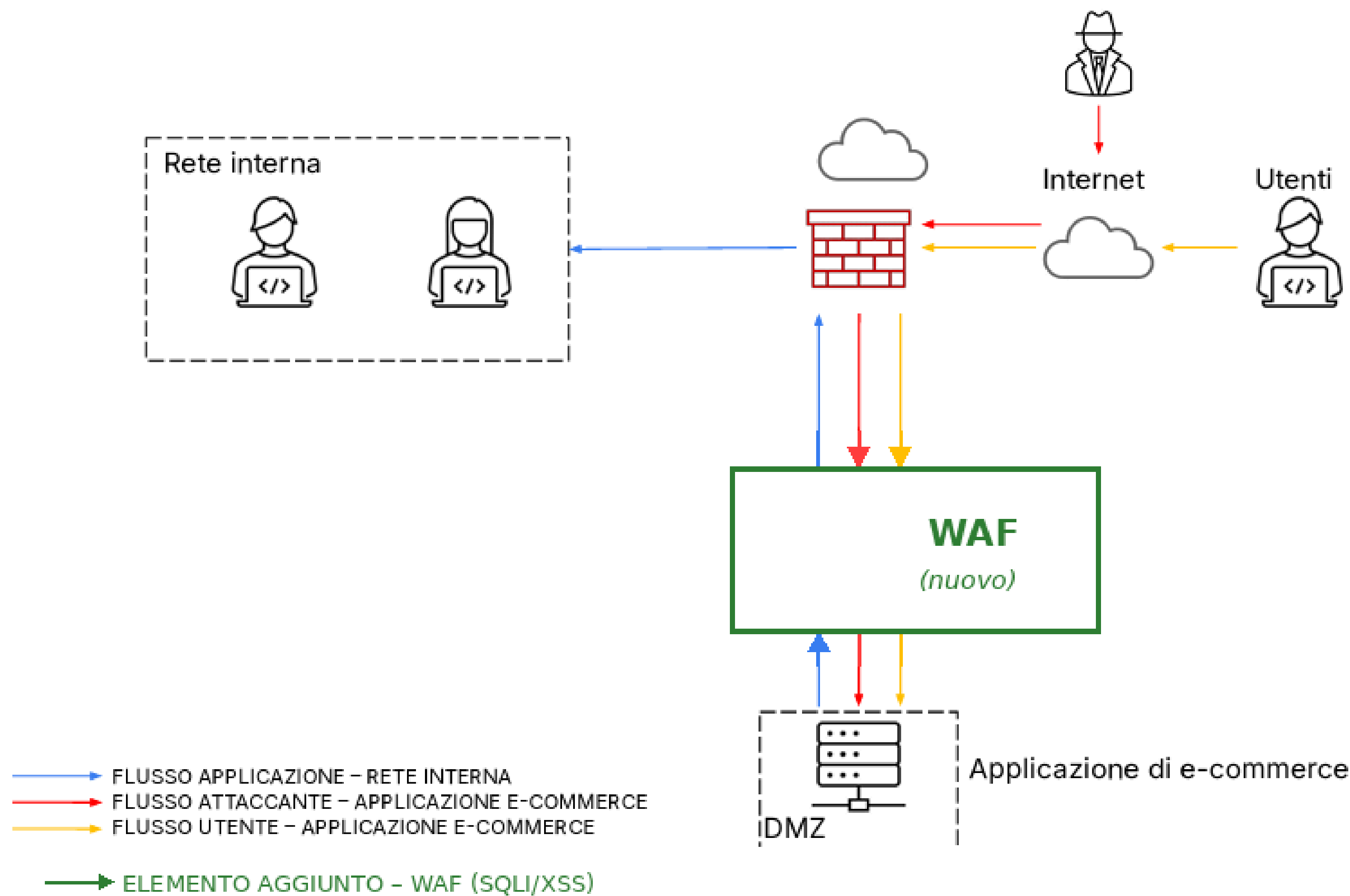


Fig. 2 — Architettura modificata: aggiunta di un Web Application Firewall (WAF) tra il Firewall perimetrale e la DMZ, a filtro dei pattern SQLi/XSS diretti verso l'applicazione

Per proteggere il sito web da manipolazioni dei dati e dall'inserimento di codice malevolo, si adottano diverse barriere complementari, per prima cosa, si installa un filtro di protezione per applicazioni web (WAF) che analizza le richieste in entrata e blocca subito quelle sospette, senza dover attendere modifiche ai programmi. A livello di codice, gli sviluppatori utilizzano istruzioni di ricerca pronte e parametrizzate, una tecnica che separa nettamente i comandi di sistema dai dati inseriti dagli utenti, impedendo che un testo inviato dall'esterno possa trasformarsi in un comando non autorizzato, si applica poi un controllo severo degli ingressi, accettando solo dati scritti nel formato corretto (come email o numeri di telefono validi) e rifiutando tutto il resto, in uscita, il sistema usa la codifica dei caratteri intelligenti, trasformando i simboli speciali affinché il browser li mostri come semplice testo invece di eseguirli come comandi, sul database aziendale si impone il principio dei permessi minimi, facendo in modo che il sito possa solo leggere e aggiornare le informazioni necessarie, senza avere l'autorizzazione di cancellare o modificare le strutture fondamentali. Infine, si imposta una regola di sicurezza per il browser (CSP) che gli impedisce di caricare elementi non autorizzati e si proteggono i cookie di autenticazione, bloccandone la lettura da parte di script esterni ed evitando che vengano inviati su connessioni non sicure.

## Controlli applicativi lato server: necessari in aggiunta al WAF

| Mitigazione                                       | Meccanismo di protezione                                                                                                                                 |
|---------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|
| <i>Prepared statements / query parametrizzate</i> | <i>difesa primaria contro SQLi: separano il codice SQL dai dati in ingresso, impedendo che l'input utente venga interpretato come comando.</i>           |
| <i>Input validation</i>                           | <i>whitelist di caratteri e formati ammessi su ogni campo di input utente.</i>                                                                           |
| <i>Output encoding</i>                            | <i>escaping dei caratteri speciali (&lt; &gt; " ' &amp;) prima di rendere in pagina contenuti derivati da input utente — difesa primaria contro XSS.</i> |
| <i>Least privilege sul database</i>               | <i>l'utenza applicativa che si connette al DB non deve avere permessi di amministrazione (DDL, drop, grant).</i>                                         |
| <i>Content Security Policy (CSP)</i>              | <i>header che limita l'esecuzione di script non autorizzati nel browser dell'utente.</i>                                                                 |
| <i>Cookie HttpOnly e Secure</i>                   | <i>riduce il danno in caso di XSS riuscito, impedendo il furto dei cookie di sessione via script.</i>                                                    |

### 3. Punto 2 — Impatti sul business: attacco DDoS

L'applicazione Web subisce un attacco di tipo DDoS dall'esterno che la rende non raggiungibile per 10 minuti. Per proteggere il servizio dai blocchi causati da un traffico eccessivo, la strategia si basa su sei azioni principali. In primo luogo, un servizio Anti-DDoS e di pulizia del traffico viene posizionato all'ingresso della rete per intercettare e bloccare il traffico malevolo prima che possa intasare i sistemi aziendali, parallelamente, l'uso di una rete per la distribuzione dei contenuti (CDN) permette di gestire le richieste da più server distinti e di memorizzare gli elementi fissi del sito, alleggerendo notevolmente il carico di lavoro complessivo. Per evitare abusi, si applica una limitazione del traffico, che impone un tetto massimo alle richieste inviabili da un singolo utente o computer in un determinato arco di tempo, invece a livello di rete, si garantisce una doppia linea di connessione a Internet con fornitori diversi, così che l'eventualità che una linea si intasi o smetta di funzionare non renda il servizio del tutto irraggiungibile, inoltre, l'infrastruttura viene dotata di ampliamento automatico delle risorse, un sistema in grado di potenziare da solo e temporaneamente la capacità dei server per reggere l'aumento delle visite, siano esse clienti reali o tentativi di attacco. Infine, la gestione operativa definisce un tempo massimo di ripristino pianificato, per fare in modo che, in caso di blocco del sistema, il servizio torni riattivato e funzionante prima che il fermo causare un danno economico inaccettabile per l'azienda

| Voce                          | Valore                                         |
|-------------------------------|------------------------------------------------|
| Durata downtime               | 10 minuti                                      |
| Spesa media della piattaforma | 1.500 €/minuto                                 |
| Impatto economico diretto     | $10 \times 1.500 \text{ €} = 15.000 \text{ €}$ |

### Impatti qualitativi: non quantificabili in valuta ma rilevanti per il business

| Impatto                       | Descrizione Tecnica                                                                                            |
|-------------------------------|----------------------------------------------------------------------------------------------------------------|
| Pubblicità negativa           | un'interruzione visibile del servizio e-commerce può generare copertura mediatica o social negativa.           |
| Sfiducia dei clienti          | gli utenti che non riescono a completare un acquisto possono spostarsi su piattaforme concorrenti.             |
| Possibili penali contrattuali | eventuali SLA con partner, marketplace o servizi di pagamento potrebbero prevedere penali in caso di downtime. |

### Valutazione di azioni preventive: mitigazioni applicabili contro attacchi DDoS

| Mitigazione                                   | Meccanismo di protezione                                                                                                                                                                                                                    |
|-----------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Servizio Anti-DDoS / scrubbing                | posizionato davanti al firewall, assorbe e ripulisce il traffico volumetrico prima che raggiunga l'infrastruttura aziendale.                                                                                                                |
| CDN (Content Delivery Network)                | distribuisce il carico su più nodi geografici e mette in cache i contenuti statici, riducendo l'impatto dei picchi di traffico.                                                                                                             |
| Rate limiting / connection throttling         | limita il numero di richieste per singola sorgente su firewall o load balancer.                                                                                                                                                             |
| Ridondanza di connettività (multi-ISP)        | evita che la saturazione di un singolo collegamento renda l'intero servizio irraggiungibile.                                                                                                                                                |
| Auto-scaling dell'infrastruttura applicativa  | assorbe picchi di traffico, legittimo o malevolo, aumentando temporaneamente le risorse disponibili.                                                                                                                                        |
| Definizione di $RTO \leq MTD$ per il servizio | in ottica di Business Continuity Plan, il Recovery Time Objective per il ripristino del servizio e-commerce deve restare sotto il Maximum Tolerable Downtime stimato dal business, per contenere l'impatto economico di eventi come questo. |

## 4. Punto 3 — Response: contenimento del malware

In questo scenario la priorità non è l'eradicazione immediata della minaccia, ma impedire che il malware si propaghi dalla DMZ verso la rete interna, sfruttando proprio il percorso di raggiungibilità evidenziato nell'architettura di partenza, al contempo, e si sceglie deliberatamente di non rimuovere l'accesso dell'attaccante alla macchina infetta: mantenere il canale attivo (sotto osservazione) permette al team di sicurezza di raccogliere indicatori di compromissione (IoC) e comprendere le tecniche dell'attaccante prima di procedere a una remediation completa

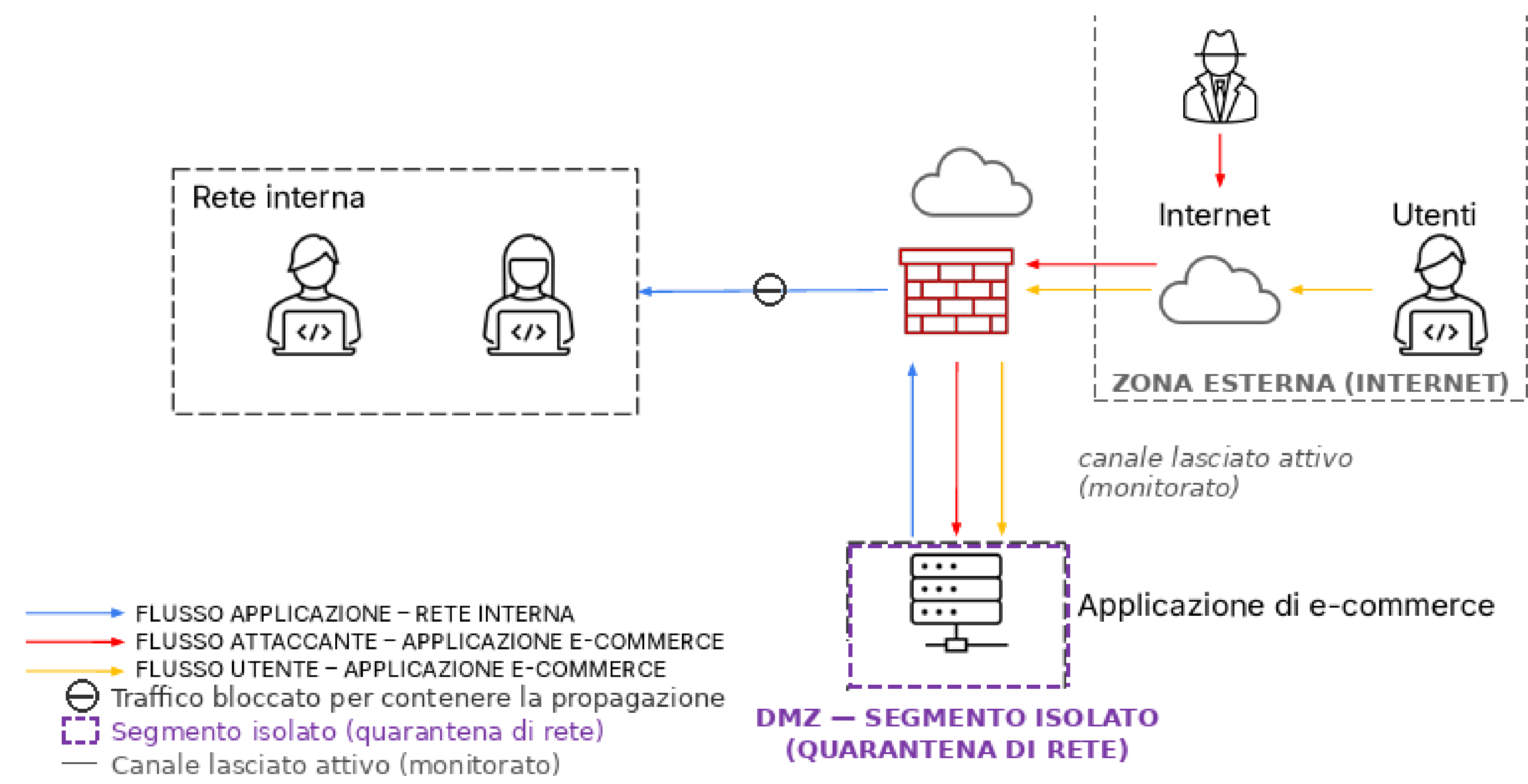


Fig. 3 — Contenimento del malware: il segmento DMZ è definito come zona isolata in quarantena (bordo viola), il traffico laterale verso la rete interna è bloccato (icona di divieto), mentre il canale con l'attaccante resta volutamente attivo e monitorato

### Contenimento a livello di rete: segmentazione / firewall interno

In caso di presenza di un programma malevolo, la priorità assoluta è evitare che l'infezione si diffonda nel resto dell'azienda, la prima misura è l'isolamento immediato della zona colpita, bloccando tutto il traffico di rete diretto verso i computer interni ma lasciando attiva la connessione verso l'esterno per poter osservare cosa sta facendo l'attaccante, viene applicato un blocco rigido dei movimenti di rete, impedendo al computer infetto di comunicare con qualsiasi altro dispositivo aziendale vicino. Sui sistemi coinvolti si installa un programma di protezione avanzato (EDR) che rileva e blocca in automatico ogni tentativo di spostamento del virus da un computer all'altro, tutte le attività vengono convogliate verso un centro di controllo della sicurezza (SIEM/SOC) per raccogliere gli indizi, analizzare i comportamenti dell'attaccante e capire esattamente come sia avvenuta l'intrusione, per garantire che le prove siano valide anche a livello legale, si procede alla conservazione delle evidenze digitali: il computer non viene né spento né riavviato, ma si estrae una copia esatta della memoria e del disco rigido prima di fare qualsiasi altra operazione. Infine, la comunicazione viene limitata ai soli addetti ai lavori, usando un canale esterno riservato per evitare che l'attaccante possa intercettare le mosse della squadra di difesa

### Contenimento a livello host: EDR sulla macchina compromessa

| Mitigazione                                              | Meccanismo di protezione                                                                                                                            |
|----------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|
| Rilevamento e blocco dei tentativi di movimento laterale | l'agente EDR sull'host DMZ blocca connessioni verso subnet interne (es. SMB, RDP) senza applicare un isolamento di rete totale della macchina.      |
| Accesso dell'attaccante mantenuto (temporaneamente)      | la connessione dall'esterno verso l'host infetto non viene interrotta, per non compromettere l'attività di osservazione e raccolta di IoC in corso. |
| Monitoraggio attivo (SOC / SIEM)                         | tutto il traffico e le attività della macchina infetta vengono registrati per l'analisi forense successiva.                                         |
| Remediation finale pianificata                           | una volta raccolte le informazioni necessarie, la macchina verrà isolata, ripulita e l'accesso dell'attaccante chiuso definitivamente.              |

## 5. Punto 4 — Scenario combinato: SQLi/XSS e malware insieme

In questo scenario le due minacce coesistono: l'applicazione resta esposta a tentativi di SQL Injection e XSS (Punto 1) mentre, contemporaneamente, un host in DMZ risulta infettato da un malware da contenere senza rimuovere l'accesso dell'attaccante (Punto 3). Le due soluzioni proposte operano su livelli diversi dello stack e possono essere applicate simultaneamente, secondo il principio della difesa in profondità (defense in depth): un singolo controllo non è mai sufficiente, per cui più livelli di difesa indipendenti si completano a vicenda. Inoltre, le informazioni e gli indizi raccolti durante la fase di analisi del virus vengono subito usati per aggiornare le regole di protezione, insegnando al filtro web come riconoscere e bloccare in futuro i metodi esatti utilizzati dall'attaccante

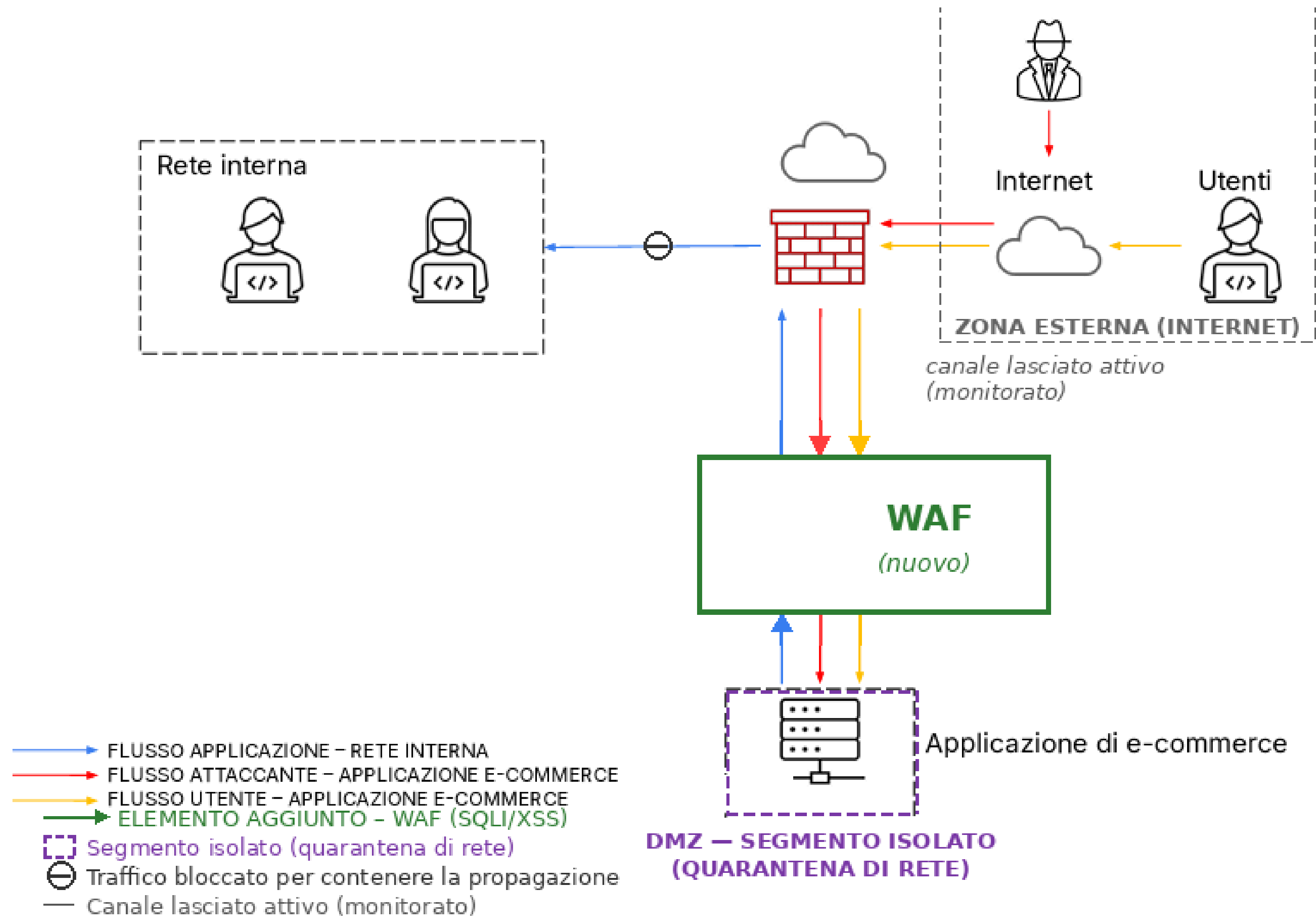


Fig. 4 — Architettura combinata: il WAF (Punto 1) resta attivo tra Firewall e DMZ, mentre la DMZ è definita come segmento isolato in quarantena con traffico laterale bloccato (Punto 3); il canale con l'attaccante resta monitorato

### Compatibilità delle due soluzioni: nessun conflitto diretto tra i controlli

| Mitigazione                                        | Meccanismo di protezione                                                                                                                                                                                                                                                              |
|----------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| WAF — livello applicativo (L7)                     | ispeziona le richieste HTTP dirette all'applicazione e blocca i pattern SQLi/XSS, riducendo la probabilità di una compromissione iniziale. Continua a operare normalmente anche in presenza dell'incidente malware, perché agisce solo sulle nuove richieste applicative in ingresso. |
| Segmentazione/quarantena — livello di rete (L3-L4) | agisce sul traffico dalla DMZ verso la rete interna, indipendentemente da come la macchina sia stata compromessa. Non richiede modifiche alle regole del WAF e non ne è influenzata.                                                                                                  |
| Canale con l'attaccante mantenuto attivo           | il traffico Internet → host infetto non passa dal WAF (non è una richiesta verso l'applicazione, ma una sessione già stabilita con l'host compromesso), quindi il monitoraggio non viene interrotto dall'introduzione del WAF.                                                        |

### Considerazioni aggiuntive: cosa cambia rispetto ai due punti trattati separatamente

L'unico accorgimento in più riguarda la causa dell'infezione: se il malware fosse stato introdotto proprio sfruttando una SQLi o una XSS non ancora coperta dal WAF (es. una regola non aggiornata), sarebbe opportuno rivedere le regole del WAF alla luce degli indicatori di compromissione raccolti durante il monitoraggio dell'host infetto (Punto 3), chiudendo così il ciclo tra rilevamento e prevenzione. A parte questo collegamento operativo, le due soluzioni restano indipendenti e compatibili senza bisogno di ulteriori modifiche architetturali

Approccio e vincoli: budget definito e proporzionalità degli interventi

Con un investimento compreso tra i 25.000 e i 35.000 euro, si realizza un piano di protezione completo e graduale. Si attiva prima di tutto un servizio di protezione completo in cloud, che unisce il filtro web, la velocizzazione del sito e la difesa dagli attacchi di traffico in un unico abbonamento, senza dover acquistare nuovi macchinari. Successivamente, si distribuisce il software di difesa avanzata (EDR) su tutti i server aziendali più importanti per bloccare sul nascere qualsiasi infezione. Si attiva poi un sistema centrale di raccolta delle informazioni (SIEM in cloud) per tenere sotto controllo tutti gli eventi di sicurezza da un unico punto. Le regole per separare la zona pubblica dalla rete aziendale vengono rese permanenti sul filtro di rete già esistente, mentre la continuità della connessione viene garantita dall'attivazione di una seconda linea Internet, con scambio automatico in caso di guasto. L'applicazione web viene distribuita su più server tramite un sistema di bilanciamento che cresce all'aumentare delle visite. Il progetto si chiude con una fase finale di verifica e collaudo, durante la quale si svolgono test pratici ed ed un controllo da parte di esperti esterni per confermare che tutte le protezioni funzionino perfettamente senza ostacolare il lavoro quotidiano

Componenti proposti e budget indicativo: stima annuale, ordine di grandezza

| Componente                                                        | Funzione nell'architettura                                                                                                | Costo indicativo annuo |
|-------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------|------------------------|
| Servizio Cloud WAF + CDN + Anti-DDoS (es. Cloudflare Business)    | Mitiga attacchi DDoS (Punto 2) e filtra pattern SQLi/XSS (Punto 1) a livello edge, riducendo il carico su firewall e DMZ. | 4.800 €                |
| Agente EDR su host critici (DMZ e rete interna)                   | Rilevamento e blocco del movimento laterale, a supporto del contenimento malware (Punto 3)                                | 3.600 €                |
| Piattaforma SIEM cloud (log management)                           | Raccolta e correlazione centralizzata dei log per monitoraggio continuo e analisi forense                                 | 6.000 €                |
| Regole di segmentazione/microsegmentazione sul firewall esistente | Isolamento della DMZ in quarantena (Punto 3), senza sostituire l'apparato già in uso                                      | 3.500 €                |
| Secondo collegamento Internet (ISP di backup)                     | Ridondanza di connettività e mitigazione aggiuntiva in caso di saturazione del link primario (Punto 2)                    | 3.200 €                |
| Load balancer gestito / auto-scaling applicativo                  | Assorbe picchi di traffico legittimo o residuo da un attacco DDoS (Punto 2)                                               | 4.500 €                |
| Implementazione, hardening e test (consulenza)                    | Configurazione, collaudo e verifica di tutte le contromisure introdotte                                                   | 4.400 €                |
| Totale                                                            |                                                                                                                           | 30.000 €               |